

Security+ 2.5 · Mitigation Techniques

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.5 — Mitigation Techniques (6:51) · [vídeo original](#) · [YouTube](#)

Técnicas de mitigação em CAMADAS: patching (a base mais esquecida); encryption (proteção do dado); monitoring/EDR (observar + responder); least privilege (menor acesso); backup (recovery); training (treinar o humano); compensating control (quando o ideal não dá).

Highlights que a prova cobra

- Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida)
- Least privilege: cada pessoa só o mínimo
- Defesa em camadas: nunca 1 solução — empilha

Dicas de prova

- 'reduces impact but doesn't eliminate vulnerability' = compensating control

Cenário clássico: Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora de perto' = compensating control.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:
 - A) Menor privilégio
 - B) Separação de funções
 - C) Rotação de cargo
 - D) Need-to-know geográfico

2. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

3. Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?

- A)** Aceitar o risco
- B)** Evitar o risco
- C)** Transferir o risco
- D)** Mitigar o risco

4. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Patching: a defesa básica mais esquecida (a maioria dos breach era patch co...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Least privilege: cada pessoa só o mínimo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Least privilege: cada pessoa só o mínimo...

6. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Defesa em camadas: nunca 1 solução — empilha'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Defesa em camadas: nunca 1 solução — empilha...

7. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'reduces impact but doesn't eliminate vulnerability' = compensating control'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'reduces impact but doesn't eliminate vulnerability' = compensating control...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora de perto' = compensating control.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora d...

9. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Patching: a defesa básica mais esquecida (a maioria dos breach era patch co...

10. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Least privilege: cada pessoa só o mínimo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Least privilege: cada pessoa só o mínimo...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Menor privilégio.** Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida.
- 2) B — Identificar, Proteger, Detectar, Responder, Recuperar.** NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na
- 3) C — Transferir o risco.** Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele.
- 4) C — Implementar a solução correspondente: Patching: a defesa básica mais esquecida (. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida). As demais alternativas con**
- 5) D — Implementar a solução correspondente: Least privilege: cada pessoa só o mínimo...** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Least privilege: cada pessoa só o mínimo. As demais alternativas configuram violações graves de conformidade ou
- 6) D — Implementar a solução correspondente: Defesa em camadas: nunca 1 solução — empil.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Defesa em camadas: nunca 1 solução — empilha. As demais alternativas configuram violações graves de conformidade
- 7) B — Implementar a solução correspondente: 'reduces impact but doesn't eliminate vuln.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): 'reduces impact but doesn't eliminate vulnerability' = compensating control. As demais alternativas configuram
- 8) D — Implementar a solução correspondente: Cenário: 'sistema industrial não pode ter .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora de perto' = compensating control.. As
- 9) D — Implementar a solução correspondente: Patching: a defesa básica mais esquecida (. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida). As demais alternativas con**
- 10) B — Implementar a solução correspondente: Least privilege: cada pessoa só o mínimo...** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Least privilege: cada pessoa só o mínimo. As demais alternativas configuram violações graves de conformidade ou

